

Controls and compliance checklist

To complete the controls assessment checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each control, including the type and purpose, refer to the [control categories](#) document.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently have this control in place?*

Controls assessment checklist

Yes	No	Control
☐	☒	Least Privilege
☐	☒	Disaster recovery plans
☒	☐	Password policies
☐	☒	Separation of duties
☒	☐	Firewall
☐	☒	Intrusion detection system (IDS)
☐	☒	Backups
☒	☐	Antivirus software
☐	☒	Manual monitoring, maintenance, and intervention for legacy systems
☐	☒	Encryption
☐	☒	Password management system
☒	☐	Locks (offices, storefront, warehouse)
☒	☐	Closed-circuit television (CCTV) surveillance

- ☒ ☐ Fire detection/prevention (fire alarm, sprinkler system, etc.)

To complete the compliance checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each compliance regulation, review the [controls, frameworks, and compliance](#) reading.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently adhere to this compliance best practice?*

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☒	Only authorized users have access to customers’ credit card information.
☐	☒	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☐	☒	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☐	☒	E.U. customers’ data is kept private/secured.
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☐	☒	Ensure data is properly classified and inventoried.

- | | | |
|-------------------------------------|--------------------------|---|
| ☒ | ☐ | Enforce privacy policies, procedures, and processes to properly document and maintain data. |
|-------------------------------------|--------------------------|---|

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
☐	☒	User access policies are established.
☐	☒	Sensitive data (PII/SPII) is confidential/private.
☒	☐	Data integrity ensures the data is consistent, complete, accurate, and has been validated.
☐	☒	Data is available to individuals authorized to access it.

As there are different types of controls which are: Preventative, Corrective, Detective, Deterrent. These controls work together to provide defense in depth and protect assets. But after reviewing the checklist we can be assured that the defense in depth is very poor in this company and there is a huge gap in protecting assets. There is a proverb that says, "Prevention is always better than cure". If we review the preventative control types there are missing controls like least privilege, separation of duties, poor password policies, password management system. These controls are very important and they should implement and schedule security audits according to compliance. Also there are lackings of corrective, detective, and deterrent controls. The first thing which is heavily messy is compliances like they just follow NIST CSF but don't follow it properly. As they want to expand their business to the EU they also have to maintain GDPR. There is another necessary PCI DSS framework which is not maintained by them.

Recommendations (optional): Firstly, they need to follow the PCI DSS compliance as their customers use online payments for buying their products. Further, they also need to ensure that the NIST CSF is followed properly. In this context, they need to verify whether all their controls belonging to different categories, i.e., Administrative, Technical, Physical Controls are implemented and maintained successfully. For preventing any attack, they must use IDS while SIEM needs to be used for continuous monitoring of their systems. In absence of least privilege, their customers' data is available to every department, which may lead to a security breach. Their account lifecycle reduces their attack surface, and they should ensure OWASP principles. They need to develop policies and procedures as per the scope and goals of their organization. Policies and procedures must be followed strictly by everyone in the organization. Training sessions should be conducted for employees so that they can follow policies and procedures properly. Lastly, a Security Awareness training needs to be conducted for their employees.